

Security+ 2.3 · Zero-day

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3 — Zero-day (3:02)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Zero-day: a vulnerability unknown to the vendor, with no patch available. Exploitation occurs before disclosure. Defense: no direct defense; rely on compensating controls such as behavioral EDR, layered defense, threat intelligence, and rapid patching once available.

High-Yield Core Concepts Tested on Exam

- Zero-day: no patch available at time of exploitation
- Exploited before vendor disclosure or patch release
- Defense relies on behavioral detection, layered security, and compensating controls
- Threat intelligence can provide early warnings of zero-day exploits
- Not every exploit is a zero-day; only those without a known patch
- Zero-day attacks are difficult to detect with signature-based tools

Exam Tips & Classic Scenarios

- 'no patch available' = zero-day
- 'exploited before disclosure' = zero-day exploit
- 'attacker exploits vulnerability vendor just discovered and no patch yet' = zero-day

Typical Exam Scenario: An attacker exploits a vulnerability in a web application that the vendor has just discovered but has not yet released a patch for. This is a zero-day attack.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — Zero-day)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **CVE:** Common Vulnerabilities and Exposures: Publicly standardized dictionary of known information security vulnerabilities and exposures.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. A vulnerability that the manufacturer does not yet know about and has no fix for is called:

- A)** Public CVE
- B)** Zero-day
- C)** Backdoor
- D)** False positive

2. What type of attack exploits vulnerabilities before a patch is available?

- A)** Zero-day attack
- B)** DDoS attack
- C)** Brute force attack
- D)** Man-in-the-Middle attack

3. Corporate scenario (Zero-day): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Zero-day: no patch available — not every known exploit is zero-day'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Zero-day: no patch available — not every known exploit is zero-day...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Zero-day): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Defense: behavior + layers + compensating control'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Defense: behavior + layers + compensating control...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Zero-day): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'no patch available' = zero-day. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'no patch available' = zero-day.
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Zero-day): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'exploited before disclosure' = zero-day exploit. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'exploited before disclosure' = zero-day exploit...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Zero-day): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: 'attacker exploits a vulnerability that the vendor just discovered and there is no patch yet' = zero-day.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Scenario: 'attacker exploits a vulnerability that the vendor just discovered and there is no patch yet' = zero-day
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Zero-day): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Zero-day: no patch available — not every known exploit is zero-day'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Zero-day: no patch available — not every known exploit is zero-day
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Zero-day): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Defense: behavior + layers + compensating control'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Defense: behavior + layers + compensating control.

10. Corporate scenario (Zero-day): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'no patch available' = zero-day'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'no patch available' = zero-day...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Zero-day.

✓ **Why it's correct:** The correct answer is 'Zero-day'. A zero-day vulnerability is one that is unknown to the software or hardware vendor at the time of exploitation. Since the manufacturer is unaware of it, no patch is available, making it highly dangerous. The term 'zero-day' refers to the fact that the vendor had 'zero days' to fix the flaw before it was exploited. The question describes exactly this situation: a vulnerability that the manufacturer does not yet know about and has no fix for. Therefore, 'Zero-day' is the exact answer according to the CompTIA syllabus.

✗ **Why the others are wrong:**

- *Public CVE:* CVE (Common Vulnerabilities and Exposures) is a reference system for publicly known vulnerabilities. A public CVE is a vulnerability that has already been disclosed, cataloged, and generally has a fix or known mitigations available. In the question, the vulnerability is unknown to the manufacturer and has no fix, which contradicts the definition of a public CVE. Therefore, this option is incorrect.
- *Backdoor:* A backdoor is an unauthorized access mechanism intentionally inserted into a system, application, or device, often by the developer or an attacker, to bypass normal authentication. Although a backdoor can be exploited without the manufacturer's knowledge, it is not necessarily an unpatched vulnerability; it can be an intentional feature or a malware artifact. The question describes an unknown and unpatched vulnerability, which is the definition of a zero-day, not a backdoor. Therefore, backdoor is not the correct answer.
- *False positive:* A false positive, in the security context, is an incorrect alert generated by detection tools (such as antivirus or IDS) that identify legitimate activity as malicious. It has no relation to unknown vulnerabilities or lack of a fix. The question deals with a real, exploitable vulnerability, not a detection error. Therefore, false positive is completely inadequate.

2) A — Zero-day attack.

✓ **Why it's correct:** The correct answer is 'Zero-day attack'. A zero-day attack exploits a vulnerability that is unknown to the software or hardware vendor, or for which no patch is yet available. The term 'zero-day' refers to the fact that exploitation occurs before the developer has had the opportunity to fix the flaw, or on the same day the vulnerability becomes known. These attacks are particularly dangerous because they cannot be mitigated by antivirus signatures or traditional patches, requiring proactive defenses such as behavioral analysis, sandboxing, and network segmentation. In CompTIA Security+, the zero-day concept is associated with advanced threats and the need for defense-in-depth strategies.

✗ **Why the others are wrong:**

- *DDoS attack:* A DDoS (Distributed Denial of Service) attack aims to overwhelm a service, server, or network with massive traffic from multiple sources, making it unavailable to legitimate users. It does not exploit a specific software vulnerability for which no patch exists; instead, it abuses resource capacity and bandwidth. Although it can be devastating, DDoS does not fit the definition of a zero-day attack, as it does not depend on an unknown and unpatched flaw. Mitigation involves traffic filtering, CDNs, and anti-DDoS services, not patch application.
- *Brute force attack:* A brute force attack attempts to guess credentials (passwords, keys) through exhaustive and repeated attempts, often automated. It exploits weak or predictable passwords, not an unpatched software vulnerability. Although it can be used for initial access, it is not classified as a zero-day attack. Defenses include strong password policies, account lockout, multi-factor authentication, and rate limiting, and do not depend on a specific patch for an unknown flaw.
- *Man-in-the-Middle attack:* A Man-in-the-Middle (MitM) attack occurs when an adversary

positions themselves between two communicating parties, intercepting and possibly altering traffic. It exploits authentication flaws, weak encryption, or insecure configurations (e.g., ARP spoofing, DNS spoofing), but is not defined by exploiting an unpatched vulnerability. MitM can be mitigated with strong encryption, digital certificates, and mutual authentication. It is not to be confused with zero-day, which specifically refers to an unknown and unpatched vulnerability.

3) A — Implement the corresponding solution: Zero-day: no patch available — not every known exploit is zero-day....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Zero-day): Zero-day: no patch available — not every known exploit is zero-day. A zero-day vulnerability is one that is unknown to the vendor and has no patch; exploits for it are zero-day attacks. However, many exploits target known vulnerabilities for which patches exist, so they are not zero-day.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: Defense: behavior + layers + compensating control....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Zero-day): Defense: behavior + layers + compensating control. Zero-day vulnerabilities have no available patch, so defenses must rely on behavioral detection (e.g., anomaly-based IDS/IPS), layered security (defense in depth), and compensating controls to mitigate the risk until a patch is available.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: 'no patch available' = zero-day..

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Zero-day): 'no patch available' = zero-day. A zero-day vulnerability is a software flaw unknown to the vendor, with no available patch or mitigation at the time of discovery. Attackers can exploit it before defenders have a chance to respond, making it a critical threat. Security+ emphasizes the need for compensating controls (e.g., virtual patching, network segmentation) and threat intelligence to mitigate zero-day risks.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaches compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: 'exploited before disclosure' = zero-day exploit....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Zero-day): 'exploited before disclosure' = zero-day exploit. A zero-day exploit targets a vulnerability that is unknown to the vendor or has not yet been patched, making it highly dangerous because defenses are not yet available. The term 'zero-day' refers to the fact that the vendor has had zero days to fix the flaw before it is exploited.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: Scenario: 'attacker exploits a vulnerability that the vendor just discovered and there is no patch yet' = zero-day.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Zero-day): Scenario: 'attacker exploits a vulnerability that the vendor just discovered and there is no patch yet' = zero-day.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: Zero-day: no patch available — not every known exploit is zero-day.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 2.3 (Zero-day): Zero-day: no patch available — not every known exploit is zero-day. A zero-day vulnerability is one that is unknown to the vendor and has no patch, but not all exploits are zero-days.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: Defense: behavior + layers + compensating control..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Zero-day): Defense: behavior + layers + compensating control. Zero-day exploits target unknown vulnerabilities, so signature-based defenses are ineffective. A robust defense strategy includes behavior-based detection (anomaly detection), layered security (defense in depth), and compensating controls (alternative measures when primary controls cannot be applied).

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: 'no patch available' = zero-day....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Zero-day): 'no patch available' = zero-day. A zero-day vulnerability is a flaw for which no patch or mitigation exists, making it highly dangerous as defenders have no official fix.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

